



XXE Reader



Bối cảnh (Context)

Công ty DataAnalytics Inc vừa tung ra một công cụ phân tích tự động. Nó cho phép doanh nghiệp tải lên danh sách nhân sự dưới định dạng XML, sau đó trả về biểu đồ phân bổ nhân lực.

Trình phân tích cú pháp (XML Parser) của họ sử dụng phiên bản cũ và được cấu hình để cho phép xử lý các thực thể ngoại vi (External Entities) nhằm mục đích... cho ngẫu.



Mục tiêu (Objective)

- **Nhiệm vụ:** Tự tay viết một file XML độc hại, lạm dụng các thực thể ngoại vi để ép máy chủ đọc file cục bộ của nó và hiển thị kết quả ra màn hình cho bạn.
- **Vấn đề / Lỗ hổng: XML External Entity (XXE) Injection.** Kẻ tấn công có thể khai báo một thực thể XML `<!ENTITY xxe SYSTEM "file:///etc/passwd">` và gọi nó trong phần thân XML. Khi máy chủ phân tích XML, nó sẽ đọc file trên ổ cứng và thay thế vào kết quả trả về.
- **Flag:** Nội dung file chứa Flag lưu trên máy chủ.



Gợi ý (Hints)

- Cú pháp để khai báo thực thể XML ngoại vi (SYSTEM) là gì?
- Đảm bảo bạn chèn biến Entity đó (ví dụ `&xxe;`) vào đúng cái trường (tag) mà hệ thống sẽ phản hồi lại cho bạn (ví dụ tag `<name>`).